

INCIDENT RESPONSE REPORT

SOC169 — IDOR Attack

Possible IDOR Attack Detected — WebServer1005

Analyst: Mehenni May · Date: 26 February 2026 · Classification: TLP:WHITE · Platform: LetsDefend

ALERT
SOC169

VERDICT
TRUE POSITIVE

OUTCOME
**ATTACK
SUCCEEDED**

ACTION
HOST CONTAINED

01 EXECUTIVE SUMMARY

This report documents the investigation of alert SOC169 — a medium-severity SIEM rule triggered by consecutive POST requests to the `/get_user_info/` endpoint on WebServer1005. The investigation followed the LetsDefend Web Attack analysis playbook and confirmed the event as a true positive IDOR (Insecure Direct Object Reference) attack. Unlike the previous SQL injection case (SOC165) where the server returned HTTP 500, this attack returned HTTP 200 with user data — the attack was successful and user data was exposed. The target host was contained as an immediate response action.

Category	Summary
What happened	An external attacker from IP 134.209.118.137 (DigitalOcean) sent consecutive POST requests to the <code>/get_user_info/</code> endpoint on WebServer1005, manipulating the <code>user_id</code> parameter to enumerate user records. The SIEM rule SOC169 triggered on the pattern of consecutive requests to the same endpoint. The requests were permitted by the network device and reached the application.
What is IDOR?	IDOR (Insecure Direct Object Reference) is a vulnerability where an application exposes internal object references — such as a database primary key (<code>user_id=1</code> , <code>user_id=2</code> , <code>user_id=3</code>) — in user-controlled parameters without verifying that the requesting user is authorised to access each record. An attacker can enumerate sequential IDs to access any user's data.
Was it successful?	YES — CONFIRMED. The server returned HTTP 200 with a 253-byte response body for the observed request (<code>user_id=2</code>). A successful IDOR attack returns HTTP 200 with non-trivial response sizes containing the requested user data. HTTP 200 + 253 bytes confirms the endpoint returned user information without authorisation checking.
Severity	MEDIUM (per SIEM classification) — however the confirmed data exposure elevates business impact. User records on the <code>/get_user_info/</code> endpoint were accessible to any unauthenticated external party able to supply a valid integer <code>user_id</code> . The scope of exposed records is proportional to the number of valid IDs the attacker enumerated.
False positive?	NO — confirmed true positive. The source IP (134.209.118.137) is a DigitalOcean VPS with no business relationship to the organisation. No planned test notification

	was found in the mailbox. Consecutive requests with sequential user_id values to a user data endpoint from an external IP is not legitimate behaviour.
Actions taken	Source IP investigated via WHOIS. Endpoint and response confirmed via Log Management. Target host WebServer1005 was contained via Endpoint Security to prevent further data access while remediation is planned. The vulnerability in the /get_user_info/ endpoint requires developer remediation (authorisation checks + access control enforcement).

02 ALERT DETAILS & INITIAL TRIAGE

2.1 SIEM Alert

Event ID	119
Alert rule	SOC169 — Possible IDOR Attack Detected
Severity	Medium
Category	Web Attack
Alert level	Security Analyst
Event time	February 28, 2022 10:48 PM
Trigger reason	Consecutive requests to the same page — sequential user_id parameter enumeration
Device action	Allowed — request was not blocked by the network device
Hostname	WebServer1005
Destination IP	172.16.17.15 (internal web server — Windows Server 2019)
Source IP	134.209.118.137 (external — DigitalOcean, LLC, AS14061)
Request method	POST
Protocol / Port	HTTPS / 443
Requested URL	https://172.16.17.15/get_user_info/
POST parameter	?user_id=2 (sequential enumeration: attacker increments user_id to access different records)
User-Agent	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; .NET CLR 1.1.4322)
Response status	HTTP 200 — OK (data was returned successfully)
Response size	253 bytes (non-trivial response body — user record data returned)

Figure 1 – SIEM: SOC169 Alert — IDOR Attack, EventID 119, WebServer1005, Source 134.209.118.137

^
Medium
Feb, 28, 2022, 10:48 PM
SOC169 - Possible IDOR Attack Detected
119
Web Attack
>> ✓

EventID :

119

Event Time :

Feb, 28, 2022, 10:48 PM

Rule :

SOC169 - Possible IDOR Attack Detected

Level :

Security Analyst

Hostname :

WebServer1005

Destination IP Address :

172.16.17.15

Source IP Address :

134.209.118.137

HTTP Request Method :

POST

Requested URL :

https://172.16.17.15/get_user_info/

User-Agent :

Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; .NET CLR 1.1.4322)

Alert Trigger Reason :

consecutive requests to the same page

Device Action :

Allowed

Show Hint

🔍

Figure 2 – Log Management: POST /get_user_info/ — HTTP 200, 253 bytes, ?user_id=2

i
Event

destination_port

443

^

time

Feb, 28, 2022, 10:45 PM

Raw Log

Request URL

https://172.16.17.15/get_user_info/

User-Agent

Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.... 🔍

Request Method

POST

Device Action

Permitted

HTTP Response Size:

253

HTTP Response Status

200

POST Parameters

?user_id=2

03 UNDERSTANDING WHY THE ALERT TRIGGERED

The LetsDefend playbook begins by requiring the analyst to understand the rule and the attack type before proceeding. This shapes every subsequent investigative decision.

3.1 Rule Analysis

Rule name	SOC169 — Possible IDOR Attack Detected
Trigger pattern	Consecutive requests to the same page

Why it triggers	An IDOR attacker systematically increments an object reference (e.g., user_id=1, user_id=2, user_id=3...) in rapid succession. This creates a pattern of repeated hits to the same endpoint with different parameter values — a signature distinct from normal user navigation.
Attack class	IDOR — Insecure Direct Object Reference
Target endpoint	/get_user_info/ — a user data retrieval endpoint that accepts a user_id POST parameter

3.2 What IDOR Is and Why It Is Dangerous

IDOR is not a payload injection technique like SQL Injection. It exploits a logic flaw: the application trusts the user-supplied object reference without verifying that the requesting identity is authorised to access the referenced object.

Concept	Detail
Object reference	user_id=2 — an integer that directly references a database row. The application accepts this value and queries the database without checking: 'Is the requesting user allowed to see user_id=2?'
Attack method	The attacker changes user_id from 1 to 2 to 3... in sequential POST requests. Each valid ID returns that user's record. No special payload or injection is required — only the ability to modify the parameter value.
Why it succeeds	The /get_user_info/ endpoint performs no session-based authorisation check. Any external caller who knows the endpoint URL and supplies a valid integer receives a user record in the HTTP 200 response body.
Business impact	Every user record in the system is accessible to the attacker. Names, email addresses, roles, and any other fields returned by the endpoint are exposed for every valid user_id in sequence.
Detection signal	The SIEM rule fires on consecutive requests — an automated sequential pattern not consistent with normal single-user navigation. A human clicking through a UI would not generate rapid sequential user_id increments.

Figure 3 – LetsDefend Playbook: Understand Why the Alert Was Triggered

Understand Why the Alert Was Triggered

In order to perform a better analysis and to determine whether the triggered alert is false positive, it is first necessary to understand why the rule was triggered. Instead of starting the analysis directly, first understand why this rule was triggered.

- Examine the rule name. Rule names are usually created specifically for the attack to be detected. By examining the rule name, you can understand which attack you are facing.
- Detect between which two devices the traffic is occurring. It's a good starting point to understand the situation by learning about the direction of traffic, what protocol is used between devices, etc.

Next

04 PLANNED TEST CHECK

Before escalating any alert, the playbook requires checking whether the triggering activity was an authorised penetration test or attack simulation. This prevents false positive escalations.

Email notification found?	No — no planned test or penetration test notification was found in the mailbox for WebServer1005, the IP 172.16.17.15, or the source IP 134.209.118.137
Attack simulation hostname?	No — 134.209.118.137 is a DigitalOcean cloud VPS (WHOIS confirmed), not an attack simulation platform such as Verodin, AttackIQ, or Picus
Conclusion	NOT a planned test — confirmed real, unsolicited external attack traffic

Figure 4 – LetsDefend Playbook: Check If It Is a Planned Test

Check If It Is a Planned Test

Penetration tests or attack simulation products can trigger False Positive alarms if the rules are not set correctly. Check whether the malicious traffic is the result of a planned test.

- Check if there is an email showing that there will be planned work by searching for information such as hostname, username, IP address on the mailbox.
- Check if the device generating malicious traffic belongs to attack simulation products. If the Hostname contains the name of Attack Simulation products (such as Verodin, AttackIQ, Picus...), these devices belong to Attack Simulation products within the framework of LetsDefend simulation and it is a planned work.

Is the malicious traffic caused by a planned test?

Not Planned

Planned

05 SOURCE IP INTELLIGENCE

The source IP 134.209.118.137 was investigated via WHOIS to characterise the attacker's infrastructure. This IP was the sole external investigation target for this alert.

5.1 WHOIS — 134.209.118.137

IP address	134.209.118.137
CIDR range	134.209.0.0/16
Net name	DIGITALOCEAN-134-209-0-0
Net handle	NET-134-209-0-0-1
Organisation	DigitalOcean, LLC (OrgId: DO-13, ASN AS14061)
Registered	2018-10-18 (updated 2020-04-03)
Type	Direct Allocation — rented VPS, not residential or corporate
Country	United States (Broomfield, Colorado — DigitalOcean corporate HQ)
Abuse contact	https://www.digitalocean.com/company/contact/#abuse
Assessment	DigitalOcean VPS infrastructure — the same cloud provider as the SOC165 attack source (167.99.169.17). DigitalOcean IPs are disproportionately used for attack infrastructure due to low cost and rapid provisioning. This is a cloud-hosted attacker VPS, not a legitimate business address.

The source IP of this IDOR attack (134.209.118.137 — DigitalOcean AS14061) uses the same autonomous system as the prior SQL injection attack source (167.99.169.17 — DigitalOcean AS14061). While this does not confirm the same actor, it is consistent with a threat actor who relies on DigitalOcean VPS infrastructure as a preferred attack launchpad. Both cases should be cross-correlated in the threat intelligence platform.

Figure 5 – WHOIS: 134.209.118.137 — DigitalOcean LLC, CIDR 134.209.0.0/16, ASN AS14061

IP WHOIS Lookup

Look up registration and network information for IP addresses using WHOIS

134.209.118.137

WHOIS Information

Discover more

[Nameserver Information Tool](#) [Website Performance Analysis](#)
[Cloud storage solutions](#) [Domain Registrar Comparison](#) [Web development services](#)

IP Whois

```
NetRange:      134.209.0.0 - 134.209.255.255
CIDR:          134.209.0.0/16
NetName:       DIGITLOCEAN-134-209-0-0
NetHandle:     NET-134-209-0-0-1
Parent:        NET134 (NET-134-0-0-0-0)
NetType:       Direct Allocation
OriginAS:
Organization:  Digitalocean, LLC (DO-13)
RegDate:       2018-10-18
Updated:       2020-04-03
Comment:       Routing and Peering Policy can be found at https://www.as14061.net
Comment:       Please submit abuse reports at https://www.digitalocean.com/company/contact/#abuse
Ref:           https://rdap.arin.net/registry/ip/134.209.0.0
OrgName:       DigitalOcean, LLC
OrgId:         DO-13
Address:       105 Edgeview Drive, Suite 425
City:          Broomfield
```

06 HTTP TRAFFIC ANALYSIS

The LetsDefend playbook instructs the analyst to examine all fields in the HTTP request — not only the URL. For IDOR attacks, the method, parameter values, response code, and response size are collectively decisive for determining whether exploitation succeeded.

6.1 Request Analysis

Protocol / port	HTTPS / 443 — encrypted transport
Method	POST — parameter is in the request body, not the URL. IDOR is not limited to GET requests; POST-based IDOR is equally exploitable.
Endpoint	/get_user_info/ — a user data retrieval function. The name directly signals that it returns user personal information.

POST parameter	?user_id=2 — a direct object reference. An integer value that maps directly to a database primary key.
Attack pattern	Consecutive requests: attacker sends user_id=1, user_id=2, user_id=3... in rapid sequence. Each valid ID returns a different user's record.
User-Agent	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; .NET CLR 1.1.4322)
UA assessment	Internet Explorer 6 / Windows XP era User-Agent — released circa 2001. Extremely outdated; characteristic of automated attack tools that use legacy browser strings as cover.
Device action	Allowed — no WAF, IPS, or firewall rule blocked these requests

6.2 Response Analysis — Attack Success Determination

For IDOR attacks, the HTTP response status code and response body size are the primary indicators of success. The playbook explicitly identifies response size as a key success indicator for IDOR attacks.

Indicator	Observed	Interpretation
HTTP Response Status	200 — OK	The server processed the request successfully and returned data. HTTP 200 on a user data endpoint after an IDOR attempt confirms the application returned the requested user record without authorisation control.
HTTP Response Size	253 bytes	253 bytes is a non-trivial response body consistent with a returned user record (name, email, role, ID fields). A 0-byte or minimal error response would indicate failure. 253 bytes confirms actual user data was served.
Combined verdict	ATTACK SUCCEEDED	HTTP 200 + 253-byte response body = user data returned to the attacker without authorisation. This is the confirmation signature for a successful IDOR exploitation. The data for user_id=2 was exfiltrated, and sequential enumeration would expose all user records.

ATTACK CONFIRMED SUCCESSFUL. HTTP 200 response + 253-byte body on the /get_user_info/ endpoint after a POST with user_id=2 confirms user data was returned to the attacker without any authorisation check. Each sequential user_id in the attacker's enumeration sequence exposed one additional user record. The total number of records exposed is proportional to the number of requests made during the attack window.

Figure 6 – LetsDefend Playbook: Examine HTTP Traffic

Examine HTTP Traffic

Check the traffic content for any suspicious conditions such as web attack payloads (SQL Injection, XSS, Command Injection, IDOR, RFI/LFI).

Examine all the fields in the HTTP Request. Since the attackers do not only attack through the URL, all the data from the source must be examined to understand whether there is really a cyber attack.

You can review the Web Attacks 101 tutorial for information about attacks on web applications and how to detect these attacks.

- [Web Attacks 101](#)

Next

Figure 7 – LetsDefend Playbook: Check Whether the Attack Was Successful

Check Whether the Attack Was Successful

Investigate whether the attack was successful. Detection mechanisms vary according to the attack type. Some tips that can help with your investigation;

- In Command Injection attacks, you can understand whether the attack was successful by looking at the "Command History" of the relevant device via Endpoint Security. In SQL Injection attacks, attackers can run commands on the device with the help of functions such as "xp_cmdshell". For this reason, you may need to look at the "Command History" in SQL Injection attacks.
- You can guess by looking at the HTTP Response size in SQL Injection and IDOR attacks.

You can access the Web Attacks 101 training below, in which we explain how you can understand whether the attack is successful or not according to the attack type.

- [Web Attacks 101](#)

Next

Because the attack was confirmed successful — user data was actively being exposed — the target host WebServer1005 was contained via Endpoint Security to immediately stop further data exfiltration while the vulnerability is remediated.

7.1 Host Information

Hostname	WebServer1005
Domain	letsdefend.local
IP address	172.16.17.15 (internal web server)
OS	Windows Server 2019 (64-bit)
Primary user	webadmin35
Client/Server	Server
Last login	February 15, 2022 01:43 PM
Role	Internal web application server — hosts the /get_user_info/ endpoint that is the subject of this IDOR attack

7.2 Containment Decision

Because the IDOR attack was confirmed to have succeeded (HTTP 200, 253-byte user data response), containment of the target server was the correct immediate response action. Containment prevents further data access from the attacker while the development team remediates the missing authorisation control on the /get_user_info/ endpoint.

Containment is the appropriate immediate action when an attack is confirmed successful and the vulnerable endpoint is actively accessible to the attacker. In this case, the /get_user_info/ endpoint has no access control — any external party can enumerate all user records. Containment breaks this access until the code-level fix is deployed.

Figure 8 – Endpoint Security: WebServer1005 — Before Containment (Containment OFF)

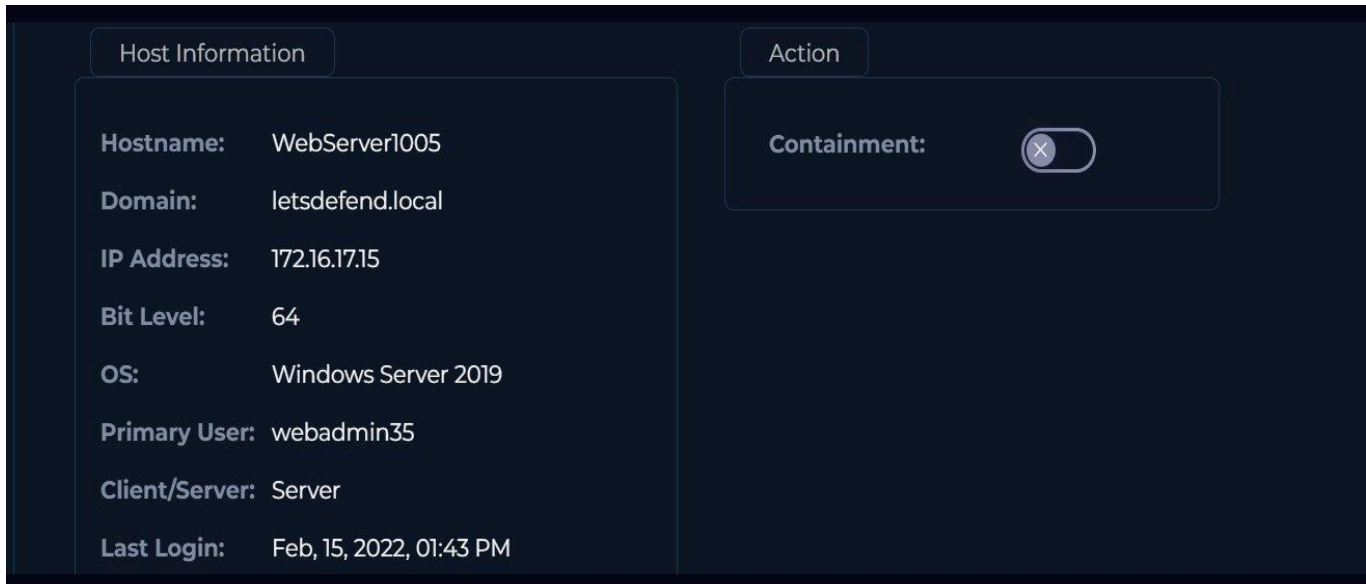


Figure 9 – Endpoint Security: WebServer1005 — After Containment (Host Contained)

Host Information

Hostname: WebServer1005

Domain: letsdefend.local

IP Address: 172.16.17.15

Bit Level: 64

OS: Windows Server 2019

Primary User: webadmin35

Client/Server: Server

Action

Containment:  **Host Contained**

08 MITRE ATT&CK® MAPPING

ID	Name	Tactic	Evidence	Detection
T1190	Exploit Public-Facing Application	Initial Access	POST to /get_user_info/?user_id=2 on WebServer1005 — application logic flaw exploited (missing authorisation on object reference).	Alert on HTTP 200 responses from user data endpoints to unauthenticated external IPs. Rate-limit consecutive requests to sensitive endpoints.
T1083	File and Directory Discovery	Discovery (adapted)	Sequential user_id enumeration — consecutive requests to same endpoint with incrementing parameter values to map all accessible user records.	Alert on consecutive requests from a single external IP to the same API endpoint within a defined time window.
T1530	Data from Cloud Storage Object	Collection (adapted)	User records (name, email, role, ID) returned by /get_user_info/ for each valid user_id. HTTP 200 + 253 bytes confirms data collection occurred.	Implement authorisation controls: validate that the authenticated session owner matches the requested user_id before returning data.
T1071.001	Application Layer Protocol: Web	Exfiltration	Data exfiltrated over HTTPS (port 443) — each 253-byte HTTP 200 response to 134.209.118.137 constitutes a data transfer event.	Monitor for high volumes of outbound HTTP 200 responses to external IPs from internal API endpoints. Flag unusual response volume patterns.

09 RISK ASSESSMENT

Dimension	Rating	Reasoning
-----------	--------	-----------

Attack success	CONFIRMED	HTTP 200 with 253-byte body on /get_user_info/ after IDOR payload confirms user data was returned. This is not a suspected or probable outcome — it is forensically confirmed.
Scope of data exposure	HIGH	The vulnerability is not limited to user_id=2. Any integer user_id that maps to a valid database record would return that user's data. The attacker's consecutive request pattern indicates systematic enumeration — all user records accessible to the endpoint are exposed.
Technical impact	HIGH	The endpoint /get_user_info/ has no authorisation control. Any external actor with knowledge of the URL can enumerate the entire user database with trivial effort. No exploit, no payload, no special skill — only the ability to increment an integer.
Business impact	HIGH	User personal data (at minimum: user ID and associated profile fields) has been exfiltrated to an external DigitalOcean VPS. Depending on the data returned by the endpoint, this may constitute a notifiable data breach under applicable data protection regulations (GDPR, etc.).
Regulatory risk	HIGH	If the /get_user_info/ endpoint returns personal data of individuals (names, email addresses, etc.), this incident may require regulatory notification within 72 hours of awareness (GDPR Article 33). Legal and compliance teams should be notified immediately.
Overall risk	HIGH	Confirmed data exfiltration. Full user database accessible via trivial enumeration. External attacker from cloud VPS infrastructure. Containment applied — but the root cause (missing authorisation logic) requires code-level remediation before the server is released from containment.

10 RECOMMENDATIONS

#	Priority	Action
1	CRITICAL	Immediately notify the application development team to implement authorisation controls on the /get_user_info/ endpoint. The fix requires verifying that the authenticated session's user identity matches the requested user_id before returning data. Until this fix is deployed, the server should remain contained.
2	CRITICAL	Notify the Legal and Compliance team about the confirmed data exfiltration. If the endpoint returns personal data (names, emails, etc.), this may be a notifiable data breach under GDPR, CCPA, or other applicable regulations. The 72-hour GDPR notification window may already be running.
3	HIGH	Block source IP 134.209.118.137 at the perimeter firewall. While the server is contained, block this IP to prevent any future access from the same attacker VPS. Consider blocking the DigitalOcean CIDR range 134.209.0.0/16 if no legitimate business traffic is expected from this range.
4	HIGH	Conduct a full audit of all API endpoints that accept user-controlled object references (user_id, account_id, order_id, etc.). Any endpoint that does not enforce session-based ownership validation before returning data is an IDOR vulnerability waiting to be exploited.
5	HIGH	Implement rate-limiting on all user data API endpoints. Consecutive requests above a defined threshold (e.g., 10 requests/minute from a single IP) should trigger automatic blocking or CAPTCHA. This would have disrupted the sequential enumeration before significant data was exposed.

6	MEDIUM	Review all logs for 134.209.118.137 across the full attack window to determine the complete range of user_id values enumerated and the total volume of data exfiltrated. This information is required for breach scope assessment and regulatory notification.
7	MEDIUM	Correlate 134.209.118.137 with the SOC165 source IP (167.99.169.17) — both are DigitalOcean AS14061. Determine whether both attacks originate from the same campaign or actor, and whether other endpoints have been probed.
8	MEDIUM	Implement a WAF rule to detect and alert on sequential numeric parameter enumeration patterns across POST requests to the same endpoint from the same source IP.
9	LOW	Close alert EventID 119 as True Positive — Attack Succeeded. Document containment action. Update SIEM/SOAR case status. Retain all investigation artefacts. Release server from containment only after the authorisation fix has been deployed and tested.

11 INDICATORS OF COMPROMISE — IOC APPENDIX

Type	Value	Context	Action
IP	134.209.118.137	Attack source — DigitalOcean VPS, AS14061, CIDR 134.209.0.0/16	Block at perimeter
IP range	134.209.0.0/16	DigitalOcean netblock — consider blocking if no business need	Review / block
URL	https://172.16.17.15/get_user_info/	Vulnerable endpoint — IDOR confirmed, no authorisation control	Contain / patch
Param	user_id (POST parameter)	Object reference used for IDOR enumeration — integer user ID	Add authz check
UA	Mozilla/4.0 (MSIE 6.0; WinNT 5.1)	IE6/WinXP era UA — automated scanner / attack tool signature	WAF UA filter
Event ID	SOC169 / EventID 119	SIEM alert — IDOR, Feb 28 2022 10:48 PM, WebServer1005	True Positive
Host	WebServer1005 (172.16.17.15)	Target — Windows Server 2019, currently contained	Keep contained

12 LESSONS LEARNED

#	Area	Lesson
1	HTTP 200 = Attack Succeeded (for IDOR)	IDOR success is determined by HTTP 200 plus a non-trivial response body size. A failed IDOR attempt returns HTTP 403 (Forbidden) or HTTP 404 (Not Found). HTTP 200 with 253 bytes on a user data endpoint after an IDOR attempt is unambiguous confirmation that data was returned. This is the direct opposite of the SOC165 SQL injection case where HTTP 500

		indicated failure — always interpret HTTP response codes in the context of the specific attack type.
2	Response Size is Decisive for IDOR	The 253-byte response body is the critical data point. An empty or error response would be near-zero bytes. A 253-byte body on <code>/get_user_info/</code> is consistent with a JSON or structured user record (name, email, role, ID). The playbook explicitly identifies response size as the IDOR success indicator — this field must always be checked alongside the status code.
3	POST IDOR is as Dangerous as GET IDOR	Many analysts associate IDOR with GET requests where the object reference is visible in the URL. This case used POST — the <code>user_id</code> parameter was in the request body. IDOR is a logic vulnerability that applies to any HTTP method that accepts an object reference parameter. Always check POST body parameters, not only URL query strings.
4	IDOR Requires No Special Payload	Unlike SQL injection, XSS, or buffer overflow, IDOR requires no encoding, obfuscation, or injected syntax. The attacker simply changed <code>user_id=1</code> to <code>user_id=2</code> . This simplicity makes IDOR trivially automatable and extremely difficult to detect by signature-based tools — it looks like normal application usage. Detection must be behavioural (rate, pattern, volume) rather than signature-based.
5	Containment Is the Right Immediate Action for Confirmed Exfiltration	When an attack is confirmed successful and data is actively being exposed, containment of the affected server is the correct immediate response — not just logging and monitoring. Containment breaks the attacker's access path before further data is exfiltrated. The trade-off is service disruption, which is preferable to continued data loss. Always contain before remediating when exfiltration is active.
6	IDOR Is a Development Failure, Not a Perimeter Failure	This attack could not have been blocked at the perimeter without disrupting legitimate users of the same endpoint. The root cause is that the <code>/get_user_info/</code> endpoint was deployed without authorisation logic — any valid <code>user_id</code> returns data to any caller. This is a code-level failure that requires a code-level fix: verify that the authenticated session identity is authorised to access the requested <code>user_id</code> before returning data. No firewall rule or WAF signature fixes this.